Modelo de Ameaças – TennisSync

Relatório Técnico de Reconhecimento e Análise de Segurança Cibernética

ENTREGA 2

1. Visão Geral

O **TennisSync** é um sistema de treinamento de tênis que analisa a técnica de golpe do jogador a partir de vídeo ao vivo utilizando estimativa de pose e um classificador de golpes baseado em aprendizado de máquina. O sistema fornece feedback biomecânico em tempo real, pontuação gamificada, clipes de replay e alertas físicos de erro articular. Trata-se de um protótipo sem gestão de contas de usuário, implantado em um host único em rede local ou compartilhada.

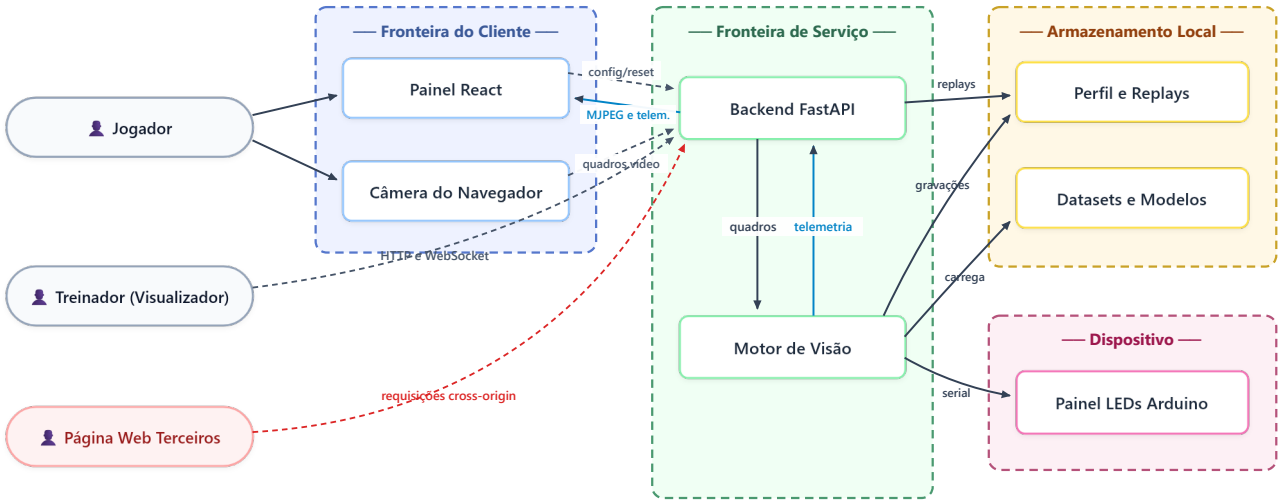
- **Frontend:** Painel de página única (SPA) em React (feed de vídeo, telemetria, histórico, cartão de jogo, replays, configurações) com fallback integrado para demonstração.
- **API de Backend:** Serviço FastAPI que expõe REST, um stream MJPEG e dois canais WebSocket (ingestão de quadros do navegador, telemetria e configuração).
- **Motor de visão e análise:** Worker em segundo plano que captura quadros da câmera, executa estimativa de pose, classificação, avaliação de regras e gamificação.
- **Armazenamento local:** Perfil do jogador e arquivo de progressão, clipes gravados de replay, datasets de treinamento e artefatos de modelo.
- **Ferramental de ML offline:** Scripts para download de datasets públicos, construção de conjuntos de treino e treinamento do modelo.
- **Painel de feedback IoT:** Microcontrolador Arduino com LEDs articulares e buzzer, controlado via comunicação serial.

> **Escopo de Análise:** O ambiente de execução da Entrega 2 (frontend, backend, armazenamento e conexão IoT) e o pipeline de dados offline. O código da Entrega 1 é uma iteração anterior dos mesmos componentes e não foi modelado separadamente.

2. Fronteiras de Confiança

- **Acesso irrestrito de rede:** O backend confia que qualquer cliente de rede capaz de alcançar sua porta seja o jogador local legítimo. *Controle:* Nenhum na camada de aplicação; a acessibilidade ao host é a única barreira.
- **Ingestão de vídeo do navegador:** O backend confia que os quadros de vídeo e mensagens JSON recebidos via WebSocket de ingestão sejam dados válidos de câmera provenientes do navegador do jogador. *Controle:* Apenas decodificação e descarte de entradas não interpretáveis (*unparseable*).
- **Consumo de dados pelo navegador:** O navegador confia que a telemetria, URLs de replay e textos de feedback enviados pelo backend sejam autênticos e seguros para renderizar e vocalizar (*speech*). *Controle:* Roteamento pelo mesmo host ou via proxy; nenhuma assinatura criptográfica de mensagens.
- **Origem de requisições web:** O backend confia no contexto de navegador de origem cruzada (*cross-origin*) que o requisita. *Controle:* Política de CORS permissiva que aceita qualquer origem web (*).
- **Interface de hardware Arduino:** O backend confia no dispositivo serial conectado ao link do Arduino e o dispositivo confia em cada byte enviado a ele. *Controle:* Apenas a conexão física USB.
- **Artefatos locais de modelo e perfil:** O motor de análise confia nos datasets, arquivos de modelo e no arquivo de perfil armazenados localmente. *Controle:* Permissões de arquivo do sistema operacional host.
- **Fontes externas de ML:** O ferramental offline confia em fontes de datasets de terceiros. *Controle:* Download via HTTPS a partir de servidores públicos.

DIAGRAMA DE ARQUITETURA, COMPONENTES E FRONTEIRAS DE CONFIANÇA



3. Cenários de Ameaça

1. Acesso não autorizado ao feed da câmera ao vivo e aos replays

Qualquer agente na mesma rede local consegue alcançar o serviço e visualizar a transmissão de vídeo ao vivo, a telemetria biomecânica e os clipes de replay gravados do atleta. O serviço presume que todo cliente com conectividade IP seja o proprietário legítimo; com isso, o invasor obtém visibilidade ininterrupta do espaço físico de treino e das filmagens corporais do jogador.

Probabilidade: Alta **Impacto: Alto**

Mitigação: Exigir autorização autenticada por sessão em todos os endpoints de vídeo, replay e telemetria, vinculando o serviço por padrão apenas à interface de loopback (*localhost*) ou a interfaces explicitamente confiáveis.

Validação: *Pentest:* tentar acessar os endpoints de streaming, arquivos de replay e canais WebSocket a partir de um segundo host não autenticado e certificar a rejeição da conexão.

2. Sequestro do estado da sessão e das entradas de análise

Um invasor sem credenciais injeta quadros espúrios, altera a configuração de lateralidade (destro/canhoto) ou redefine a sessão e o jogo. Essa brecha explora a premissa de que qualquer conexão aberta é do jogador legítimo, corrompendo pontuações gamificadas, métricas históricas, progressão atlética e o fluxo de vídeo exibido ao atleta real.

Probabilidade: Alta **Impacto: Médio**

Mitigação: Implementar autenticação e validação estrita de origem nos canais de controle e ingestão, garantindo a exclusividade de uma única fonte autorizada de vídeo por sessão.

Validação: *Pentest:* transmitir quadros de câmera e requisições de reset/configuração partindo de clientes não autorizados ou de origens cruzadas, atestando que o estado permanece inalterado.

3. Abuso entre sites (Cross-Site Abuse) via navegador da vítima

Uma página web arbitrária acessada pelo usuário dispara requisições HTTP ou abre conexões WebSocket contra o serviço local. Devido à ausência de restrições de CORS/origem, o site terceiro malicioso pode acionar mudanças de estado ou extrair dados sensíveis de telemetria e gravações de treino.

Probabilidade: Média **Impacto: Médio**

Mitigação: Restringir as origens aceitas estritamente à URL do dashboard oficial e verificar formalmente o cabeçalho `Origin` no handshake de upgrades WebSocket.

Validação: *Teste Automatizado:* enviar requisições REST e tentativas de handshake WebSocket partindo de origens não autorizadas e confirmar o bloqueio imediato.

4. Exaustão de recursos do pipeline de análise (Negação de Serviço – DoS)

Um invasor inunda o canal de ingestão com cargas multimídia superdimensionadas, formatos corrompidos ou mantém dezenas de conexões de streaming ativas simultaneamente. Como a inferência de aprendizado de máquina demanda alto poder computacional e compartilha um único motor e estado global, o processamento se degrada, paralisa o feedback do atleta ou causa crash no serviço.

Probabilidade: Média **Impacto: Médio**

Mitigação: Estabelecer limites rígidos por conexão para tamanho de mensagem, taxa de quadros (FPS) e conexões simultâneas, além de isolar falhas de parsing para impedir interrupção do worker de análise.

Validação: *Pentest:* submeter pacotes malformados e rajadas de alto volume de frames por conexões simultâneas, aferindo a estabilidade e disponibilidade contínua do serviço.

5. Adulteração de modelos, datasets ou comandos de hardware

Um invasor com privilégios de gravação nos arquivos de modelo, bases de dados ou na linha serial altera o comportamento do classificador, métricas de evolução ou comandos físicos aos atuadores. Pela confiança implícita em artefatos locais, arquivos maliciosos podem gerar orientações errôneas ou executar código arbitrário na inicialização.

Probabilidade: Baixa **Impacto: Alto**

Mitigação: Checar a integridade de artefatos de IA via hashes criptográficos prévios e empregar formatos seguros e estáticos de serialização (como *safetensors*), banindo desserializadores perigosos (como *pickle*).

Validação: *Revisão de Código & Teste:* auditar a rotina de carga de modelos garantindo validação de integridade e verificar rejeição diante de arquivo de teste intencionalmente modificado.

4. Fragilidades Arquiteturais

Ausência total de camada de identidade e autorização

Toda e qualquer capacidade do sistema — incluindo acesso à câmera, manipulação de estado do jogo e recuperação de gravações em vídeo — depende estritamente do alcance de rede IP. Uma única porta acessível expõe controle absoluto do sistema sem qualquer controle secundário.

Compartilhamento monolítico de estado global

Todos os usuários, sessões e o motor de análise compartilham uma instância única de estado em memória para todo o processo. Não existe isolamento multi-tenant: a injeção de dados por qualquer cliente impacta instantaneamente todos os demais observadores, e uma única falha ou entrada maliciosa compromete todo o serviço.

Captura e retenção de vídeo sem controles de privacidade

Filmagens corporais de indivíduos são registradas e disponibilizadas sem mecanismos de consentimento, termos de retenção ou controles de privacidade. A criticidade e sensibilidade dos dados é alta, contraposta a uma defesa baseada exclusivamente em localização física/rede.